

13017 《计算机网络与信息安全》

考前资料

考试题型及分值分布

类别	题型	题量	分值/题	总分
选择题	单项选择题	20 题	1 分	20 分
非选择题	填空题	10 题	2 分	20 分
	简答题	4 题	6 分	24 分
	综合应用题	3 题	12 分	36 分

第一章 计算机网络与信息安全概述

★★考点 1: 计算机网络的定义 (单选、填空)

计算机网络是计算机技术与通信技术相互融合的产物, 是利用通信设备与链路或网络, 互连位置不同、功能自治的计算机系统, 并遵循一定规则实现信息交换的系统, 也可简单概括为互连的、自治的计算机的集合。“自治”指计算机系统彼此独立, 不存在主从或控制关系; “计算机”应理解为“计算机设备”, 包括智能计算设备。

★★考点 2: 网络协议的定义及三要素 (单选、填空、简答)

(1) 定义: 网络协议是计算机网络中的实体间在进行数据交换过程中必须遵循的规则或约定。

(2) 三要素: 语法定义实体之间交换信息的格式与结构等; 语义定义实体之间交换信息中的控制信息含义及响应方式等; 时序定义实体之间交换信息的顺序以及速度匹配方式。

★★考点 3: 计算机网络的功能-资源共享 (单选、简答)

(1) 硬件资源共享 (如 CPU、存储资源、I/O 设备等)

(2) 软件资源共享 (如远程访问大型软件, SaaS 是典型形式)

(3) 信息资源共享 (如通过网络获取新闻、检索信息等)。

★★考点 4: 计算机网络的分类 (单选、填空)

(1) 按覆盖范围: 分为个域网 (PAN, 覆盖范围 1-10m, 用于个人设备间短距离通信)、局域网 (LAN, 10m-1km, 如办公室、校园等局部区域内的网络)、城域网 (MAN, 5-50km, 覆盖一个城市范围)、广域网 (WAN, 几十到几千公里, 实现异地网络互连)。

(2) 按拓扑结构: 有星形拓扑 (中央结点是关键, 优缺点分明)、总线型拓扑 (采用共享总线, 易产生冲突)、环形拓扑 (数据单向或双向传输, 环中结点故障影响大)、网状拓扑 (可靠性高但结构复杂)、树形拓扑 (是总线型或星形的扩展)、混合拓扑 (由多种简单拓扑混合而成)。

(3) 按交换方式: 分为电路交换网络、报文交换网络和分组交换网络。

(4) 按网络用户属性: 分为公用网 (面向公众提供服务, 如电信网络、Internet) 和私用网 (面向特定组织内部, 不向公众开放, 如军事专用网络)。

★★★考点 5: 数据交换技术 (单选、简答、综合应用)

(1) 电路交换: 最早出现, 如电话网络。通信前需建立专用电路 (包括建立、传输、拆除三个阶段), 通信过程中独占信道, 实时性好但信道利用率低, 适用于语音和视频等实时性业务。

(2) 报文交换: 发送方把信息构成完整报文, 以存储-转发方式传送, 不需要建立连接, 链路利用率高, 但延迟时间长且不固定, 现代计算机网络未采用。

(3) 分组交换: 将报文分割成小分组传输, 采用存储-转发方式, 是目前计算机网络广泛采用的技术。与报文交换相比, 具有交换设备存储容量要求低、速度快、可靠传输效率高、更加公平等优点; 分组长度

的选择与多种因素有关，目前国际电信联盟给出了标准分组长度范围。

★★★考点 6：计算机网络主要性能指标（单选、填空、计算、综合应用）

(1) 速率与带宽：速率指网络单位时间内传送数据量，基本单位是 bit/s；带宽在计算机网络中常表示链路或信道的最高数据传输速率，单位也是 bit/s。

(2) 时延：包括结点处理时延、排队时延、传输时延 ($d = L/R$, L 为分组长度, R 为链路带宽) 和传播时延 ($d = D/V$, D 为物理链路长度, V 为信号传播速度), 分组从源主机到目的主机的时延是各跳步时延之和。

(3) 时延带宽积：一段物理链路的传播时延与链路带宽的乘积，单位是 bit，表示链路可容纳的比特数。

(4) 丢包率：用于衡量网络拥塞程度，丢包率=丢失分组总数/发送分组总数。

(5) 吞吐量：单位时间内源主机通过网络向目的主机实际送达的数据量，受多种因素影响，理想情况下约等于瓶颈链路的带宽。

★★★考点 7：计算机网络体系结构（单选、填空、简答）

(1) 分层体系结构：将网络通信功能分层，各层协议集合构成网络体系结构。典型的有 OSI 参考模型和 TCP/IP 参考模型。

(2) OSI 参考模型：分为 7 层，从低层至高层分别是物理层（实现无结构比特流传输，规定接口特性）、数据链路层（实现相邻结点间可靠数据传输，包括成帧、差错控制等功能）、网络层（解决分组传输和路由选择问题，包括寻址等功能）、传输层（实现端到端控制，包括复用/分解等功能）、会话层（建立、管理和终止通信对话，实际中功能常被应用层覆盖）、表示层（处理数据语法，实现格式转换等功能，部分功能也被应用层实现）、应用层（提供网络服务接口，如文件传送、电子邮件等）。各层数据通过封装和层间接口传递，对等层通信是虚拟通信。

(3) TCP/IP 参考模型：包括 4 层，应用层（合并了 OSI 模型中会话层和表示层功能，如 WWW 服务、文件传输等应用的协议在此层）、传输层（包括 TCP 和 UDP 协议，为进程提供逻辑通信机制）、互联网络层（核心层，解决分组传输和路由问题，包括 IP 协议等）、网络接口层（未详细定义，对应 OSI 模型的数据链路层和物理层）。

(4) 五层参考模型：结合 OSI 和 TCP/IP 参考模型，包括物理层、数据链路层、网络层、传输层与应用层，是描述计算机网络常用的参考模型。

★★★考点 8：信息安全基本概念（单选、填空）

(1) 定义：在技术和管理上为数据处理系统建立的安全保护，保护信息系统的硬件、软件及相关数据不因偶然或者恶意的原因遭到破坏、更改及泄露。

(2) 目的：确保以电磁信号为主要形式的、在计算机网络化系统中获取、处理、存储、传输和应用的信息内容在各个物理及逻辑区域中安全存在，并不发生任何侵害行为。

★★★考点 9：信息安全威胁（单选、简答）

(1) 基本类型：包括信息泄露（破坏机密性）、信息伪造（破坏真实性和不可否认性）、完整性破坏（破

坏完整性)、业务否决或拒绝服务 (破坏可用性)、未经授权访问 (破坏可控性)。

(2) 主要表现形式: 攻击原始资料 (人员泄露、废弃介质窃取等)、破坏基础设施 (电力、通信网络等)、攻击信息系统 (物理侵入、特洛伊木马等)、攻击信息传输 (窃听、业务流分析等)、恶意伪造 (业务欺骗、假冒等)、自身失误 (权限标志泄露)、内部攻击 (合法实体利用权限从事非法行为)。

★★★考点 10: 信息安全体系结构 (单选、填空、简答)

(1) 面向目标的体系结构: 信息安全的三个基本目标是机密性、完整性和可用性 (CIA 三元组), 还有可追溯性、抗抵赖性等原则。

(2) 面向应用的层次型技术体系结构: 信息系统基本要素包括人员、信息、系统, 对应五个安全层次, 即物理安全 (涉及网络及信息系统物理设施保护)、运行安全 (保护系统运行过程和状态)、数据安全 (保护数据处理过程)、内容安全 (保护合法信息, 监管非法信息)、管理安全 (规范人的信息行为)。

(3) OSI 安全体系结构: 定义了五大类安全服务 (鉴别服务、访问控制、数据机密性、数据完整性和抗抵赖性) 和八类安全机制 (加密、数字签名、访问控制等), 以及相应的安全管理。

第二章 网络应用与应用层协议

★★考点 1: 网络应用体系结构 (单选、填空、简答)

- (1) 分类: 分为客户/服务器 (C/S) 结构、纯 P2P 结构和混合结构。
- (2) C/S 结构: 通信在客户与服务器之间进行, 服务器运行在高性能计算机上, 有固定地址, 客户软件运行在普通设备上, 是通信主动发起方, 如 WWW 应用、FTP、电子邮件等。
- (3) 纯 P2P 结构: 没有传统服务器, 通信在对等方之间直接进行, 每个对等方兼具客户与服务器特征, 网络规模伸缩性强, 如文件分发、共享等应用。
- (4) 混合结构: 结合了 C/S 和纯 P2P 结构, 有中心服务器, 也有对等端间直接通信, 对等方通过服务器注册、查找信息, 共享或通信时直接交互。

★★考点 2: 网络应用通信基本原理 (单选、简答)

- (1) 基本通信方式: 客户/服务器通信, 应用进程间遵循应用层协议交换报文, 通过套接字 (Socket) 与底层协议交互, 用 IP 地址和端口号标识应用进程。
- (2) 传输层服务: 不同应用对传输层服务需求不同, Internet 传输层提供 TCP (面向连接、可靠的字节流传输) 和 UDP (无连接、不可靠的数据报传输) 两种服务。

★★★考点 3: 域名解析系统 (DNS) (单选、填空、简答、综合应用)

- (1) 层次化域名空间: 域名结构由标号序列组成, 如 “...三级域名.二级域名.顶级域名”, 顶级域名包括国家或地区顶级域名、通用顶级域名、基础结构域名等。
- (2) 域名服务器: 包括根域名服务器 (全球有限个, 知道所有顶级域名服务器信息)、顶级域名服务器 (管理二级域名)、权威域名服务器 (保存特定区域主机域名到 IP 地址映射)、中间域名服务器, 主机配置的默认域名服务器即本地域名服务器。
- (3) 域名解析过程: 分为递归解析 (本地域名服务器代替查询并返回最终结果) 和迭代解析 (服务器只告知下一步查询的服务器), 域名服务器通过缓存机制和存储顶级域名服务器信息等策略提升查询效率。

★★★考点 4: Web 应用 (单选、填空、简答、综合应用)

- (1) 应用结构: 主要包括 Web 服务器、浏览器与超文本传输协议 (HTTP), 通过 URL 寻址 Web 页面或对象。
- (2) HTTP: 是 Web 应用的应用层协议, 经历多个版本, 目前主流是 HTTP/1.1。基于 TCP 传输, 分为非持久连接 (每次请求传输一个对象都新建 TCP 连接, 传输后断开) 和持久连接 (可重用连接传输多个对象, 又分非流水方式和流水方式, HTTP/1.1 默认流水方式)。HTTP 报文由起始行、首部行、空白行和报文主体组成, 分为请求报文和响应报文, 不同首部行携带不同信息, 状态码用于通告响应情况。
- (3) Cookie: 是网站为辨别用户身份等存储在用户本地终端的数据, 由服务器端生成, 通过 HTTP 响应报文的 Set-Cookie 头行发送, 浏览器存储管理, 再次请求时通过 Cookie 头行携带, 可用于实现用户会话。

跟踪等功能，但存在安全问题。

★★★考点 5: Internet 电子邮件 (单选、填空、简答、综合应用)

(1) 系统结构: 主要包括邮件服务器、简单邮件传输协议 (SMTP)、用户代理和邮件读取协议。邮件服务器负责发送、接收和管理邮件, 用户代理提供使用接口, SMTP 用于邮件服务器之间及用户代理到邮件服务器的邮件传输, 邮件读取协议 (如 POP3、IMAP、HTTP) 用于用户读取邮箱中的邮件。

(2) SMTP: 是核心应用层协议, 使用 TCP 实现可靠传输, 通过握手、邮件传输和关闭三个阶段完成邮件传送, 只能传送 7 位 ASCII 码文本, 有“推动”协议、使用持久连接等特点。

(3) 电子邮件格式与 MIME: 邮件由首部、空白行和主体组成, MIME 用于解决 SMTP 传输非 7 位 ASCII 码文本的问题, 通过定义编码规则和增加首部行, 实现非 7 位 ASCII 码内容的传输。

(4) POP3 和 IMAP: POP3 是简单邮件读取协议, 功能有限, 使用 TCP, 交互过程分授权、事务处理和更新三个阶段; IMAP 比 POP3 功能更强大, 支持在远程服务器上管理邮件, 可读取邮件部分内容。

★★★考点 6: 文件传输的应用特点 (FTP) (单选、填空、简答)

(1) 是实现文件互传的网络应用

(2) 采用客户/服务器方式, 使用 TCP 可靠传输服务

(3) 通过控制连接 (21 号端口, 持久连接, 传输控制信息) 和数据连接 (20 号端口, 临时连接, 传输文件内容) 实现文件传输

(4) 具有带外控制、有状态等特点。

★★★考点 7: P2P 应用优势 (单选、简答、综合应用)

以文件分发为例, 与客户/服务器体系结构相比, P2P 体系结构中每个对等方既是数据获取者又是提供者, 能充分利用对等方的计算能力和网络带宽, 其最小分发时间几乎不随对等方数量增加而显著增加, 而客户/服务器体系结构的分发时间随用户数量增加而线性增加。

★★★考点 8: Socket 编程基础 (单选、填空、简答)

(1) Socket 类型: 网络应用进程可创建数据报类型套接字 (SOCK_DGRAM, 面向 UDP 接口)、流式套接字 (SOCK_STREAM, 面向 TCP 接口) 和原始套接字 (SOCK_RAW, 面向网络层协议接口, 创建有一定权限限制)。

(2) SocketAPI 函数: 如创建套接字 (socket 函数)、绑定地址 (bind 函数)、监听连接 (listen 函数, 仅用于服务器端 TCP 套接字)、连接服务器 (connect 函数, 用于客户端)、接受连接 (accept 函数, 用于服务器端 TCP 套接字)、发送数据 (send 函数用于 TCP 套接字和已连接的 UDP 客户端套接字, sendto 函数用于 UDP 服务器端套接字或未连接的 UDP 客户端套接字)、接收数据 (recv 函数用于 TCP 套接字和已连接的 UDP 客户端套接字, recvfrom 函数用于 UDP 服务器端套接字或未连接的 UDP 客户端套接字) 等, 基于 TCP 和 UDP 的客户程序与服务器程序调用这些函数的过程不同。

第三章 传输层服务与协议

★★考点 1: 传输层的功能 (单选、填空)

- (1) 传输层寻址
- (2) 对应用层报文分段和重组
- (3) 差错检测
- (4) 实现进程间端到端可靠数据传输控制
- (5) 复用与分解
- (6) 流量控制
- (7) 拥塞控制。

★★考点 2: 传输层寻址与端口 (单选、填空、简答)

传输层利用“IP 地址+端口号”唯一标识一个通信端点。端口号为 16 位整数, 分为熟知端口号 (0-1023)、登记端口号 (1024-49151) 和客户端口号 (49152-65535)。服务器端使用熟知端口号和登记端口号, 客户端使用临时分配的端口号。

★★考点 3: 无连接服务与面向连接服务 (单选、简答)

无连接服务数据传输前无须与对端进行信息交换, 如 UDP; 面向连接服务在数据传输前需建立逻辑连接, 传输结束后拆除连接, 如 TCP。二者分别类似邮政信件通信和电话通信的模式。

★★★考点 4: 传输层的复用与分解 (简答、综合应用)

(1) 复用指多个应用进程共用同一个传输层协议, 分解指传输层将接收到的数据准确交付给不同应用进程。

(2) UDP 依据目的 IP 地址和目的端口号二元组唯一标识一个 UDP 套接字实现分解, 源端口号起到“返回地址”作用。

(3) TCP 基于源 IP 地址、源端口号、目的 IP 地址和目的端口号四元组唯一标识一个 TCP 套接字 (即一条 TCP 连接) 实现分解。

★★★考点 5: 可靠数据传输基本原理 (简答、综合应用)

实现可靠数据传输的措施包括差错检测 (利用差错编码)、确认 (ACK 和 NAK)、重传 (发送方重发未正确接收的数据)、序号 (确保数据按序提交)、计时器 (解决数据丢失问题)。这些措施综合应用, 可应对底层信道的不可靠性。

★★★考点 6: 停-等协议 (简答、计算、综合应用)

(1) 停-等协议每发送一个报文段就等待接收方确认。工作过程包括发送方发送经差错编码和编号的报文段, 接收方正确接收则发 ACK, 否则发 NAK 或重复 ACK, 发送方根据确认信息决定是否重发。

(2) 序号字段只需 1 位, 实际常只用 ACK 确认, 通过重复 ACK 替代 NAK。该协议简单、所需缓冲

存储空间小，但信道利用率低。

★★★考点 7：滑动窗口协议（简答、计算、综合应用）

(1) 滑动窗口协议允许发送方在收到确认前连续发送多个分组，提高信道利用率。发送方和接收方各维护一个窗口，发送窗口表示可发送未确认分组的最大数量，接收窗口表示可接收并缓存的正确到达分组的最大数量。

(2) 典型的滑动窗口协议有 GBN 协议和 SR 协议。GBN 协议发送窗口 ≥ 1 ，接收窗口=1，采用累积确认，接收方无缓存能力；SR 协议发送窗口和接收窗口都大于 1，每个分组独立确认和计时。

(3) 滑动窗口协议的窗口大小与报文段序号空间需满足约束条件： $W_{\text{发送窗口}} + W_{\text{接收窗口}} \leq 2^k$ (k 为报文段序号字段的位数)。

★★★考点 8：UDP 的特点与报文段结构（单选、填空、简答）

(1) UDP 提供无连接、不可靠、数据报尽力传输服务，只实现了基本的复用/分解和简单差错检测功能。

(2) UDP 报文段首部包含源端口号、目的端口号、长度和校验和字段，应用层数据存于数据字段。校验和用于检测报文段传输过程中的差错，计算时包括 UDP 伪首部、首部和数据三部分。

★★★考点 9：TCP 的特点与报文段结构（单选、填空、简答、综合应用）

(1) TCP 提供面向连接、可靠、有序、字节流传输服务，全双工通信。通信前需建立连接，通信结束后释放连接。

(2) TCP 报文段由首部字段和数据字段组成。首部包含源端口号、目的端口号、序号、确认序号、首部长、保留、接收窗口、校验和、紧急指针、选项和填充等字段。各字段有不同作用，如序号用于对应用层数据字节编号，确认序号用于期望接收字节序号。

★★★考点 10：TCP 连接管理（简答、综合应用）

(1) 连接建立（三次握手）：主机 A 发 SYN 报文段 ($\text{SYN}=1, \text{seq}=\text{x}$)，进入 SYN_SENT 状态；主机 B 回 SYNACK 报文段 ($\text{SYN}=1, \text{ACK}=1, \text{seq}=\text{y}, \text{ack_seq}=\text{x}+1$)，进入 SYN_RCVD 状态；主机 A 再发 ACK 报文段 ($\text{ACK}=1, \text{seq}=\text{x}+1, \text{ack_seq}=\text{y}+1$)，双方进入 ESTABLISHED 状态。前两次握手报文段不携带数据但占序号，第三次可带数据。

(2) 连接拆除（四次挥手）：主机 A 发释放报文段 ($\text{FIN}=1, \text{seq}=\text{u}$)，进入 FIN_WAIT_1 状态；主机 B 回确认段 ($\text{ACK}=1, \text{seq}=\text{v}, \text{ack_seq}=\text{u}+1$)，进入 CLOSE_WAIT 状态，主机 A 进入 FIN_WAIT_2 状态；主机 B 再发释放报文段 ($\text{FIN}=1, \text{seq}=\text{w}, \text{ack_seq}=\text{u}+1$)，进入 LAST_ACK 状态；主机 A 发确认段 ($\text{ACK}=1, \text{seq}=\text{u}+1, \text{ack_seq}=\text{w}+1$)，进入 TIME_WAIT 状态，等 2MSL 后进入 CLOSED 状态，主机 B 收到后也进入 CLOSED 状态。

第四章 网络层服务与协议

★★考点 1: 网络层服务 (单选、填空、简答)

(1) 网络层主要功能包括转发和路由选择。转发指路由器根据分组目的地址决策输出链路并转移分组；路由选择是确定分组从源主机到目的主机的路径，通过路由选择算法实现。

(2) 网络层连接建立，在虚电路网络中存在，是从源主机到目的主机所经路径，涉及路径上网络层设备。分组交换网络据此分为虚电路网络和数据报网络。

★★考点 2: 虚电路网络与数据报网络 (单选、填空、简答)

(1) 数据报网络：按目的主机地址路由选择，分组独立处理，“无连接”，分组传输路径和顺序可能不同，网络本身不处理丢失和差错，由传输层负责，转发表信息更新慢。

(2) 虚电路网络：在网络层提供面向连接服务，通信前需建立和拆除虚电路。虚电路由源到目的的路径、各链路虚电路号及交换机转发表接续关系构成。分组按虚电路号转发，能保证顺序，有永久型和交换型之分，与数据报网络在多方面存在差异。

★★★考点 3: 网络互连与网络互连设备 (简答、综合应用)

(1) 异构网络互连策略：包括协议转换和构建虚拟互联网络，IP 网络是典型的虚拟互联网络。同构网络互连可采用隧道技术。

(2) 路由器结构：由输入端口、交换结构、输出端口和路由处理器组成。各部分功能不同，输入端口负责接收处理数据并缓存；交换结构实现分组转发；输出端口缓存并封装分组发送；路由处理器执行指令、维护路由表。

★★考点 4: 网络层拥塞控制 (单选、填空、简答)

(1) 拥塞原因：包括缓冲区容量、传输线路带宽、网络结点处理能力有限以及网络故障等。拥塞控制可从增加网络资源（拥塞预防）和减小网络负载（拥塞消除）两方面着手。

(2) 拥塞控制方法：流量感知路由通过动态调整链路权值均衡负载；准入控制用于虚电路网络，审核新建虚电路；流量调节通过通知上游降低发送速率消除拥塞；负载脱落则是主动丢弃数据报减轻网络负载。

★★★考点 5: IPv4 协议 (单选、填空、简答、综合应用)

(1) IPv4 数据报格式：包含版本、首部长度、区分服务等多个字段，各字段有特定作用，如标识用于分片重组，TTL 防止数据报在网络中无限循环。

(2) IP 数据报分片：当数据报长度超过链路 MTU 时，若 DF=0 则分片，由目的主机重组。分片时各分片的标识、MF 标志位、片偏移字段等有特定设置规则。

★★★考点 6: IPv4 编址 (单选、填空、简答、综合应用)

(1) 地址分类：IPv4 地址有分类地址和无类地址。分类地址分 A、B、C、D、E 五类，A、B、C 类可分配给主机或路由器，有特殊地址和私有地址。无类地址采用 CIDR 表示法，网络前缀可变。

(2) 子网划分与路由聚合：子网划分是将大子网划分为小子网，提高地址利用率，需同时给出子网地址和子网掩码。路由聚合是将多个子网合并为大子网，减少路由表项，提高查找效率，需满足一定条件。

★★考点 7：动态主机配置协议与网络地址转换（单选、填空、简答）

(1) DHCP：在应用层实现，传输层用 UDP。主机接入网络时通过 DHCP 发现、提供、请求、确认四个阶段获取 IP 地址及相关信息。

(2) NAT：运行在私有网络边缘路由器，通过替换 IP 地址和端口号，实现私有地址主机与公网通信。NAT 穿透技术可解决外网主机主动与内网主机通信的问题，有静态配置和动态配置两种方式。

★★考点 8：ICMP 与 IPv6（单选、填空、简答）

(1) ICMP：用于主机或路由器间的差错报告与网络探测，报文分为差错报告报文和询问报文，不同类型和代码代表不同功能，如“源点抑制”“路由重定向”等。

(2) IPv6：为解决 IPv4 问题而提出，数据报格式有变化，地址长度扩展到 128 位，包括单播、组播和任播地址。IPv4 向 IPv6 迁移可采用双协议栈和隧道技术。

★★★考点 9：路由算法（简答、综合应用）

(1) 链路状态路由选择算法：全局式算法，路由器构建网络拓扑图，利用 Dijkstra 算法求最短路径。需记录到目的结点的当前路径距离、前序结点等信息，通过迭代计算得到到各结点的最短路径并构建转发表。

(2) 距离向量路由选择算法：分布式算法，基于 Bellman-Ford 方程，每个结点根据与邻居的链路距离和邻居通告的距离向量，异步迭代计算到各目的结点的最短距离，可能产生无穷计数问题，可通过毒性逆转技术或定义最大有效费用度量值解决。

★★★考点 10：路由协议（简答、综合应用）

(1) RIP：基于距离向量路由选择算法的 IGP，以跳数度量路径，适用于网络直径不超过 15 跳的自治系统，相邻路由器通过 RIP 响应报文交换距离向量，报文封装在 UDP 中。

(2) OSPF：基于链路状态选择算法的 IGP，适用于较大规模的 AS，具有安全、支持多条相同费用路径等优点，报文直接封装在 IP 数据报中。

(3) BGP：Internet 的 EGP，用于 AS 间交换路由信息，通过 BGP 会话实现，有 OPEN、UPDATE 等多种报文类型，基于多种属性选择最佳路由。

★★考点 11：层次化路由选择（简答）

(1) 将大规模互联网划分为多个自治系统（AS），每个 AS 内运行相同路由协议和算法计算内部路由，AS 间通过网关路由器交换路由可达性信息。

(2) 层次化路由分为自治系统内路由选择和自治系统间路由选择，路由器转发表由这两种路由选择协议共同设置。

第五章 数据链路层服务与局域网

★★考点 1: 数据链路层服务 (单选、填空、简答)

数据链路层提供组帧、链路接入、可靠交付、差错控制和流量控制服务。

- (1) 组帧是在数据前后添加帧头和帧尾, 用于帧定界和包含控制信息;
- (2) 链路接入在广播链路中需协调多结点通信;
- (3) 可靠交付并非所有协议都提供, 视链路情况而定;
- (4) 差错控制用于检测和处理传输差错;
- (5) 流量控制防止接收方被数据淹没。

★★★考点 2: 差错控制方式 (单选、填空、简答)

- (1) 检错重发: 发送端编码, 接收端检测出错后请求重发, 如停-等协议和滑动窗口协议。
- (2) 前向纠错: 接收端利用纠错编码直接定位并纠正错误, 适用于单工链路或实时性要求高的应用。
- (3) 反馈校验: 接收端将数据发回发送端比对, 原理简单但需反向信道, 效率低。
- (4) 检错丢弃: 适用于实时性要求高、允许一定差错的系统, 直接丢弃错误数据。

★★★考点 3: 差错编码原理与汉明距离 (单选、填空、简答、计算)

- (1) 差错编码原理是在数据基础上附加冗余信息, 建立数据关联关系, 接收端据此检测错误。
- (2) 汉明距离: 编码集的汉明距离与检错、纠错能力相关。检错码汉明距离 $d_g=r+1$ 时可检测 r 位差错; 纠错码汉明距离 $d_g=2r+1$ 时可纠正 r 位差错。

★★★考点 4: 典型差错编码 (单选、填空、简答、计算)

- (1) 奇偶校验码: 包括奇校验码和偶校验码, 利用 1 位冗余信息实现差错检测, 编码简单但检错率为 50%。
- (2) 汉明码: 典型线性分组码, 可纠正单个比特差错, 信息位为 k 位时, 需增加 r 位冗余位满足 $2^r \geq k+r+1$
- (3) 循环冗余码 (CRC): 广泛应用, 通过生成多项式计算冗余校验和, 检错能力强、编码解码简单、效率高。

★★★考点 5: 多路访问控制协议分类 (单选、填空、简答)

- (1) 信道划分 MAC 协议: 采用多路复用技术, 如 FDM、TDM、WDM、CDMA, 将信道资源分配给不同用户, 适用于网络负载重的情况。
- (2) 随机访问 MAC 协议: 站点随机发送数据, 易冲突, 如 ALOHA 协议 (纯 ALOHA 和时隙 ALOHA)、CSMA 协议 (非坚持、1-坚持、P-坚持)、CSMA/CD 协议。
- (3) 受控接入 MAC 协议: 包括集中式控制 (如轮询技术) 和分散式控制 (如令牌技术), 通过预约信道使用权避免冲突, 但存在开销和等待时间问题。

★★★考点 6: CDMA 工作原理 (简答、计算)

- (1) CDMA 通过相互正交的码组编码各路原始信息码元, 实现信道共享。每个站点分配唯一码片序列,

发送数据时用码片序列对原码元编码，接收端利用码组正交特性分离信号。

★★★考点 7：以太网相关知识（单选、填空、简答、综合应用）

(1) CSMA/CD 协议：经典以太网采用，发生冲突时采用二进制指数退避算法，最短帧长为 64 字节，数据字段最少 46 字节，冲突域内信号往返时延决定最短帧长。

(2) 以太网帧结构：包含前导码、目的地址、源地址、类型字段、数据字段和 CRC 字段，前导码用于时钟同步，类型字段标识上层协议。

(3) 以太网技术：包括 10Base-T、快速以太网、千兆位以太网、万兆位以太网等，各有特点和适用场景，数据传输速率不断提升。

★★★考点 8：交换机工作原理（简答、综合应用）

(1) 转发和过滤：依据帧的目的 MAC 地址查询交换表，决策是否转发及转发端口，交换表通过自学习构建。

(2) 自学习过程：交换机初始交换表为空，通过检查帧的源 MAC 地址学习端口与 MAC 地址的对应关系，不断完善交换表。

(3) 优点：能消除冲突、支持异质链路、便于网络管理，可收集网络信息、隔离异常网络适配器。

★★考点 9：虚拟局域网（VLAN）（单选、填空、简答）

(1) 概念：基于交换机的逻辑分割广播域，将一个物理局域网在逻辑上划分成多个相对独立的广播域，不同 VLAN 间的设备通信需通过三层设备（如路由器）进行转发。

(2) 划分方式：

① 基于端口划分：最常用，将交换机端口划分到不同 VLAN，简单直接，便于管理，但灵活性差。例如，可将交换机的 1-4 端口划分为 VLAN10，5-8 端口划分为 VLAN20。

② 基于 MAC 地址划分：根据设备网卡的 MAC 地址分配 VLAN，用户移动设备时无需重新配置，适用于对移动性要求高的场景。不过，初始配置工作量大，且 MAC 地址表维护复杂。

③ 基于上层协议类型或地址划分：依据 IP 地址、IPX 地址或应用协议（如 TCP、UDP 端口号）划分，能实现基于应用的 VLAN 划分，满足不同业务需求，但对设备性能要求较高。

(3) 优点：

① 抑制广播风暴：缩小广播域范围，减少网络中广播流量，提高网络性能和安全性。

② 增强网络安全性：不同 VLAN 间默认无法直接通信，可通过访问控制列表（ACL）等方式灵活设置访问权限，防止非法访问。

③ 便于网络管理：按部门、业务等逻辑划分 VLAN，使网络管理更具针对性，故障排查和隔离更方便。

④ VLAN 标签：IEEE802.1Q 协议定义了 VLAN 标签格式，在以太网帧的源地址字段和类型字段之间插入 4 字节的 VLAN 标签，包含 2 字节的 TPID（标签协议标识，值为 0x8100）和 2 字节的 TCI（标签控制信息，包含 VLANID 等信息），用于标识帧所属的 VLAN。

⑤ VLAN 间通信：不同 VLAN 的设备不能直接二层通信，需借助路由器或三层交换机实现三层转发。路由器可通过子接口方式，为每个 VLAN 配置一个子接口，子接口对应不同 VLANID，实现 VLAN 间通信；三层交换机则利用其三层转发功能，通过路由表进行 VLAN 间的数据包转发，转发效率更高。

第六章 物理层

★★考点 1: 物理层基本概念 (单选、填空、简答)

(1) 物理层定义: 为数据链路层提供物理连接, 透明传输比特流, 规定接口和传输媒体的特性。

(2) 主要任务: 确定与传输媒体接口相关的特性, 如机械特性 (尺寸、形状等)、电气特性 (电压范围等)、功能特性 (各引脚功能) 和过程特性 (事件实现顺序)。

★★考点 2: 数据通信系统模型 (单选、填空)

(1) 组成部分: 信源 (产生数据)、发送器 (将信源数据转换为适合传输的信号)、信道 (信号传输的物理媒介)、接收器 (从信道信号中提取数据)、信宿 (接收数据) 以及噪声源 (干扰信号传输)。

(2) 通信方式分类: 按信息交互方式分为单工 (单向通信, 如广播)、半双工 (双向交替通信, 如对讲机) 和全双工 (双向同时通信, 如电话); 按数据传输方式分为并行传输 (多位数据同时传输, 适用于短距离高速通信) 和串行传输 (数据逐位传输, 常用在长距离通信)。

★★考点 3: 导引型传输介质 (单选、填空、简答)

(1) 双绞线: 分屏蔽 (STP) 和非屏蔽 (UTP), 由两根绝缘导线按规则绞合, 价格便宜、应用广泛, 常用于局域网连接, 不同类别 (如 Cat5、Cat6 等) 性能不同。

(2) 同轴电缆: 由内导体、绝缘层、外导体和护套组成, 抗干扰能力强, 曾用于有线电视网络和早期计算机网络。

(3) 光纤: 利用光在光导纤维中传播, 具有通信容量大、损耗低、抗干扰能力强等优点, 分多模光纤 (适用于短距离、低速率通信) 和单模光纤 (适用于长距离、高速率通信)。

★★考点 4: 非导引型传输介质 (单选、填空、简答)

(1) 无线通信通过自由空间传输电磁波, 按频率范围不同, 分为无线电波 (用于广播、移动通信等)、微波 (如卫星通信、地面微波接力通信)、红外线 (用于短距离通信, 如遥控器) 和激光 (可用于视距通信, 但易受天气影响)。

(2) 传播方式: 地波传播沿地球表面传播, 信号稳定, 适合长波、中波; 天波传播依靠电离层反射, 传播距离远, 但信号易受干扰; 视线传播在视距范围内直线传播, 常用于微波通信和卫星通信。

★★★考点 5: 信道的分类与特性 (单选、填空、简答)

(1) 按传输信号分: 模拟信道 (传输连续变化的模拟信号) 和数字信道 (传输离散的数字信号)。

(2) 按传输介质分: 有线信道 (如双绞线、同轴电缆、光纤等构成的信道) 和无线信道 (利用自由空间传播电磁波的信道)。

(3) 信道特性: 包括信道带宽 (单位时间内信道可传输的最大信号频率范围)、信道容量 (信道无差错传输信息的最大速率) 以及误码率 (传输错误的码元数占传输总码元数的比例)。

★★★考点 6: 基带传输 (单选、填空、简答)

(1) 基带信号：由数据直接转换的原始电信号，如矩形脉冲信号。基带传输即直接在信道中传输基带信号，数字基带传输系统主要由发送滤波器、信道、接收滤波器、抽样判决器和同步提取电路组成。

(2) 数字基带信号编码：常见码型有单极性不归零码（用高电平和零电平分别表示 1 和 0）、双极性不归零码（用正电平和负电平分别表示 1 和 0）、曼彻斯特编码（每位中间有电平跳变，用于时钟同步）和差分曼彻斯特编码（每位开始处电平跳变表示 0，不跳变表示 1）。

★★★考点 7：频带传输（单选、填空、简答、综合应用）

(1) 频带传输概念：将基带信号调制到高频载波上进行传输，通过调制解调器实现。调制方式分为模拟调制（如调幅 AM、调频 FM、调相 PM）和数字调制（如幅移键控 ASK、频移键控 FSK、相移键控 PSK）。

(2) 二进制数字调制：2ASK 通过改变载波幅度表示数字信号；2FSK 通过改变载波频率表示数字信号；2PSK 通过改变载波相位表示数字信号，2DPSK 克服了 2PSK 的“倒 π ”现象。多进制数字调制（如 4PSK、8PSK 等）可提高频谱利用率。

★★考点 8：多路复用技术（单选、填空、简答）

(1) 频分多路复用（FDM）：不同信号调制到不同频率范围，在频域上分开传输，如广播电台。

(2) 时分多路复用（TDM）：将时间划分为时隙，不同信号在不同时隙传输，又分为同步 TDM（时隙分配固定）和异步 TDM（按需分配时隙）。

(3) 波分多路复用（WDM）：在光纤通信中，将不同波长的光信号复合在一起传输，本质是频分多路复用用在光域的应用。

(4) 码分多路复用（CDM）：每个用户分配唯一的码片序列，利用码片序列的正交性在同一信道中传输，如 CDMA 移动通信系统。

★★考点 9：物理层接口标准（单选、填空、简答）

(1) RS-232：应用广泛的串行通信接口标准，定义了电气特性、机械特性和过程特性，常用于计算机与调制解调器、终端设备等的连接。

(2) USB（通用串行总线）：高速、即插即用的接口标准，支持热插拔，有多种版本（如 USB2.0、USB3.0、USB4.0 等），传输速率不断提升，可连接多种外部设备。

(3) IEEE802.3（以太网物理层标准）：规定了以太网物理层的电气、机械和功能特性，涵盖不同传输介质和速率的以太网标准，如 10Base-T、100Base-TX、1000Base-T 等。

★★考点 10：同步技术（单选、填空、简答）

同步目的：使收发双方在时间基准上保持一致，确保数据正确传输。分为：

(1) 位同步（保证收发双方的时钟频率一致，如外同步法、自同步法）

(2) 帧同步（确定帧的起始和结束位置，如字节计数法、使用字符填充的首尾定界符法、使用比特填充的首尾标志法）。

★★考点 11：传输介质的选择考虑的因素（简答、综合应用）

(1) 传输距离（如双绞线适合短距离，光纤适合长距离）

- (2) 传输速率 (光纤支持高速率, 不同类别双绞线支持不同速率)
- (3) 抗干扰能力 (光纤和屏蔽双绞线抗干扰强, 非屏蔽双绞线较弱)
- (4) 成本 (双绞线成本低, 光纤相对较高)
- (5) 应用场景 (如家庭网络常用双绞线, 骨干网络常用光纤)。

第七章 无线网络与移动网络

★★考点 1: 无线网络基本结构 (单选、填空、简答)

(1) 无线网络由无线主机、无线通信链路、基站和网络基础设施构成。无线主机是运行应用程序的端系统设备, 如便携机、智能手机等; 无线通信链路用于连接主机与基站或其他主机, 不同链路技术传输速率和距离不同; 基站在无线主机和网络基础设施间起数据链路层中继作用, 像蜂窝网络中的蜂窝塔和 IEEE802.11 无线局域网中的接入点 (AP) 都是基站; 网络基础设施通常是大规模有线网络, 如 Internet、公司网络等。

(2) 无线网络模式分为基础设施模式和自组织网络模式。基础设施模式下, 无线主机通过基站接入网络, 由网络提供地址分配和路由选择等服务; 自组织网络模式中没有基站, 无线主机直接通信, 且需自行提供路由选择、地址分配等功能。

★★考点 2: 无线链路与无线网络特性 (单选、填空、简答)

(1) 无线链路具有信号强度衰减、干扰和多径传播的特性。信号在穿过物体或自由空间时会衰减, 导致信号强度随距离增加而减弱; 同一频段的电波源会相互干扰, 环境中的电磁噪声也会形成干扰; 多径传播使接收方收到的信号模糊, 且移动的物体还会导致多径效应随时间改变。

(2) 与有线链路相比, 无线链路比特差错更常见, 这使得无线网络的多路访问控制协议更为复杂。为应对这一情况, 无线链路协议 (如 IEEE802.11 的 MAC 协议) 不仅采用 CRC 错误检测码, 还使用链路层 ARQ 协议重传受损的帧。

★★★考点 3: 移动网络基本原理 (单选、填空、简答、综合应用)

(1) 移动网络中移动结点通过无线通信技术改变与网络连接位置。从网络层角度, 用户移动性有不同情形, 在建筑物内走动且与同一接入点关联时, 从网络层看未移动; 驾车穿越多个无线接入网并希望保持 TCP 连接时, 用户是移动的; 携带便携机从一个地方到另一个地方并在新地方接入网络, 同样属于移动情况。

(2) 移动结点有永久地址和转交地址, 归属代理和外部代理负责移动管理。间接路由选择时, 通信者将数据报发往移动结点永久地址, 归属代理截获后转发给外部代理, 再由外部代理转给移动结点; 直接路由选择可避免三角路由问题, 但需要解决移动用户定位和 COA 更新问题。

★★★考点 4: IEEE802.11 无线局域网 (单选、填空、简答、综合应用)

(1) IEEE802.11 体系结构包含基站 (AP) 和基本服务集 (BSS)。无线主机可通过被动扫描 (监听信标帧) 或主动扫描 (广播探测帧) 发现 AP, 之后选择 AP 发送关联请求帧, AP 回应关联响应帧完成关联, 并通过 DHCP 获取网络配置信息。

(2) IEEE802.11 的 MAC 协议为 CSMA/CA, 通过 RTS 和 CTS 帧交换预约信道, 可有效避免隐藏站问题, 减少数据帧传输冲突。帧结构有控制帧、数据帧和管理帧, 数据帧的地址字段在不同传输场景下有不

同取值和意义。

★★考点 5: 蜂窝网络 (单选、填空、简答)

(1) 蜂窝网络体系结构中, 小区由收发基站覆盖, 基站控制器负责资源分配和切换, 移动交换中心管理用户鉴别、账户和呼叫。以 2G 蜂窝网络 GSM 为例, 其采用 FDMA/TDMA 组合技术, 每个小区的覆盖区域大小受多种因素影响。

(2) 蜂窝网络的移动性管理采用间接路由选择, 归属网络的 HLR 和被访网络的 VLR 协同工作。2G、3G、4G 和 5G 网络在技术标准、业务能力和性能指标上不断发展, 如 5G 具有高速率、低延迟、高连接密度等特点。

★★考点 6: 移动 IP 网络 (单选、填空、简答、综合应用)

(1) 移动 IP 由代理发现、向归属代理注册及数据报传输的间接路由选择三部分组成。代理发现可通过代理通告 (外部代理或归属代理广播 ICMP 报文) 或代理请求 (移动结点广播请求报文) 实现。

(2) 向归属代理注册时, 移动结点或外部代理将 COA 注册到归属代理。数据报传输采用间接路由选择, 保证移动结点在移动过程中通信的连续性。

★★考点 7: 其他典型无线网络 (单选、填空、简答)

(1) WiMax 是一种城域网技术, 可提供远距离 (达 50km)、高速宽带接入 (最高可达 300Mbit/s), 但存在服务质量差、组网性能低、产业基础薄弱以及与传统蜂窝网络兼容性差等问题, 难以成为主流 3G/4G 标准。

(2) 蓝牙是低功率、小范围、低速率的“电缆替代”技术, 工作于 2.4GHz 无线电波段, 采用 TDM 和跳频扩频技术, 设备自组织成微微网, 一个微微网最多包含 8 个活动设备, 其中一个为主设备, 其余为从设备。

(3) ZigBee 网络结点分为“简化功能设备”和“全功能设备”。多个“简化功能设备”在单个“全功能设备”控制下作为从设备运行, 多个“全功能设备”可配置为网状网络。ZigBee 网络将时间划分为超帧, 采用 CSMA/CA 随机接入方式。

★★考点 8: 无线网络中的隐藏站问题 (单选、简答)

(1) 隐藏站问题是指在无线链路中, 由于信号衰减和阻挡, 站点间无法相互检测到对方发送信号, 导致同时向同一接收方发送数据时发生碰撞的现象。

(2) 例如, 站点 A 和 C 同时向站点 B 发送数据, 但 A 和 C 互相检测不到对方信号, 造成 B 无法正确接收数据。CSMA/CA 协议通过 RTS 和 CTS 帧的交换, 让其他站点知晓通信情况, 从而避免隐藏站问题。

★★考点 9: IEEE802.11 无线局域网的关联过程 (简答)

(1) 无线主机通过扫描信道发现 AP, 可选择被动扫描监听信标帧或主动扫描广播探测帧的方式。

(2) 发现 AP 后, 无线主机选择其中一个 AP 发送关联请求帧, AP 收到后发送关联响应帧, 完成关联。之后, 无线主机通过关联的 AP 发送 DHCP 发现报文, 获取 IP 地址、子网掩码等网络配置信息, 成功加入子网。

★★考点 10: 移动网络中的三角路由问题 (单选、简答)

(1) 三角路由问题出现在移动网络的间接路由选择中, 即便通信者与移动结点之间存在更有效的路由, 数据报也要先发送给归属代理, 再转发到外部网络, 增加了传输延迟和网络负担。

(2) 例如, 通信者与移动结点在地理位置上较近, 但数据报仍需迂回经过归属代理, 造成不必要的传输开销。直接路由选择旨在解决该问题, 但会引入移动用户定位和 COA 更新等新的复杂性。

★★考点 11: 蜂窝网络的通信过程 (单选、填空、简答)

(1) 以 2G 蜂窝网络为例, 移动用户向蜂窝网络服务提供商订购服务, 该网络成为其归属网络。通信者呼叫移动用户时, 呼叫先通过公共电话网到达归属 MSC。

(2) 归属 MSC 查询 HLR 确定移动用户位置, 获取漫游号码 (MSRN), 若 HLR 没有则查询 VLR 获取。之后, 归属 MSC 向被访网络的 MSC 呼叫, 最终连接到移动用户。

★★考点 12: 5G 网络的关键技术 (单选、填空、简答)

(1) 毫米波技术使用高频段频谱, 提供更高带宽和数据传输速率, 但覆盖范围相对较小, 适用于高密度用户和热点区域。

(2) 大规模 MIMO 通过大量天线阵列实现空间复用和波束成形, 提高频谱效率和覆盖范围, 适应高流量需求场景。网络切片将物理网络切分为多个虚拟网络, 针对不同应用场景提供定制化服务, 提高网络灵活性和利用率。

(3) 移动边缘计算在网络边缘部署计算和存储资源, 降低延迟, 提高应用响应速度, 适用于自动驾驶、AR/VR 等低延迟需求场景。

第八章 密码学基础

★★考点 1: 密码学概述 (单选、填空、简答)

(1) 密码学包含密码编码学和密码分析学。加密通信模型由明文、密文、密钥、加密算法和解密算法构成,一套可用密码体系需满足加密和解密的正确性以及密钥安全性。

(2) 密码分析攻击形式有唯密文攻击、已知明文攻击、选择明文攻击、自适应选择明文攻击、选择密文攻击和选择密钥攻击,不同攻击形式获取的信息和破解难度不同。

★★★考点 2: 传统加密算法 (单选、填空、简答、计算)

(1) 简单替代密码包括移位密码、乘数密码和仿射密码。移位密码将字母表右移 k 个位置并模运算,如凯撒密码是其典型应用;乘数密码通过将明文字母乘以密钥 k 并模运算进行加密,要求 k 与模互素;仿射密码是移位密码和乘数密码的结合,加密变换为 $E(m) = (k_1m+k_2) \bmod q$

(2) 多表替代密码以一系列替代表对明文进行替代加密,能隐藏单字母出现的频度分布,如维吉尼亚密码。换位密码通过重新排列明文的字符位置进行加密,包括周期置换密码和列置换密码,周期置换密码按固定长度分组并换位,列置换密码按密钥规定的列顺序换位。

★★★考点 3: 对称密钥加密算法 (单选、填空、简答、计算)

(1) Feistel 分组密码结构将明文分成左、右两部分,经过多轮置换、替代操作得到密文,其安全性取决于分组长度、子密钥大小、循环轮数、子密钥产生算法和轮函数等因素。

(2) DES 是 16 轮的 Feistel 结构分组密码,分组长度和初始密钥长度均为 64 位,有效密钥长度 56 位。其加密过程包括初始置换、16 轮加密、轮函数运算和逆初始置换,每轮子密钥由初始密钥生成。

(3) 密码分组链接 (CBC) 模式下,每个明文组加密前与前一组密文按位“异或”,首个明文组与初始向量 IV 异或,可隐藏明文模式信息,但误差传递较大。三重 DES 通过多次加密扩展密钥长度,有多种模型,如 DES-EDE2 应用较广泛。

★★考点 4: 公开密钥加密算法 (单选、填空、简答、计算)

(1) 公开密钥密码使用两个独立的密钥,基于单向陷门函数,解决了密钥分发问题。Diffie-Hellman 密钥交换算法基于有限域中计算离散对数的困难性,用于通信双方交换密钥。

(2) RSA 算法是典型的公开密钥密码,基于大整数因子分解问题和欧拉定理。密钥生成时选择两个互异素数 p 和 q 计算 n 和 $\phi(n)$,选择合适的 e 并计算 d 。加密时用公钥,解密时用私钥。

(3) 其他公开密钥密码如 Rabin 密码基于求合数的模平方根难题,ElGamal 算法既能加密又能签名,基于有限域上的离散对数问题,椭圆曲线密码体系 (ECC) 基于椭圆曲线上的离散对数问题,具有抗攻击性强、计算量小等优势。

★★考点 5: 散列函数 (单选、填空、简答、计算)

(1) 散列函数用于消息完整性检测,将任意长消息映射成固定长度的散列值。其健壮性要求包括无碰

撞特性（弱无碰撞和强无碰撞）和单向性，以抵抗各种伪造攻击。

(2) MD5 算法对输入文本分组处理，经填充、初始化链接变量、四轮运算后得到 128 位散列值。SHA-1 算法与 MD5 类似，输入消息经填充、初始化缓冲区等操作后输出 160 位消息摘要，两者在散列值长度、分组处理长度等方面存在差异。

★★考点 6：密码学新进展（单选、填空、简答）

(1) 混沌密码学利用混沌系统的特性进行加密，如混沌系统的伪随机特性、对初始状态的敏感性等与密码学要求吻合，已有不少基于混沌的加密算法被提出。

(2) 量子密码将量子态作为信息载体，由量子力学原理保证安全性，已进入实用化阶段。DNA 密码伴随 DNA 计算发展，利用 DNA 计算的高并行性等特点，但也对传统密码体制提出挑战。

★★考点 7：对称密钥加密与公开密钥加密的区别（简答）

(1) 对称密钥加密的加密和解密使用相同密钥，加密效率高，但密钥分发困难，存在安全隐患。

(2) 公开密钥加密使用两个不同的密钥，公钥公开，私钥保密，解决了密钥分发问题，但计算量较大。通常两者联合使用，在密钥交换时用公钥加密，数据传输时用对称密钥加密。

★★考点 8：Feistel 分组密码结构的加密与解密过程（简答、计算）

(1) 加密过程：将明文分成左、右两部分

(2) $P = (L_0, R_0)$ ，进行 n 轮计算， $L_i = R_{i-1}$ ， $R_i = L_{i-1} \oplus F(R_{i-1}, K_i)$ ，其中 F 是轮函数， K_i 是第 i 轮使用的子密钥，最终输出密文 $C = (L_n, R_n)$ 。

(3) 解密过程：是加密过程的逆过程，输入密文 (L_n, R_n) ，进行 n 轮计算， $R_{i-1} = L_i$ ， $L_{i-1} = R_i \oplus F(R_{i-1}, K_i)$ ，最终得到明文 (L_0, R_0) 。计算时需根据给定的明文、密钥及轮数，按照公式逐步计算每一轮的结果。

★★考点 9：DES 算法的子密钥生成过程（简答、计算）

(1) 给定 64 位的密钥 K ，通过置换选择 1 (PC-1) 去掉奇偶校验位，并重排得到 56 位初始密钥。

(2) 将 56 位初始密钥分成左、右等长的 28 位，分别记为 C_0 和 D_0 。对于 $1 \leq i \leq 16$ ，计算 $C_i = LS_i(C_{i-1})$

(3)， $D_i = LS_i(D_{i-1})$ ，其中 LS_i 表示循环左移 1 位（当 $i=1,2,9,16$ 时）或 2 位（当 $i=1,2,9,16$ 时）。

(4) 将每轮 56 位的数据 $C_i D_i$ 用置换选择 2 (PC-2) 作用，去掉特定位并重新排列，输出得到 48 位的子密钥 K_i 。需掌握置换选择 1 和置换选择 2 的具体置换规则，根据给定密钥计算出各轮子密钥。

★★考点 10：数字签名与消息认证的区别（简答）

(1) 消息认证主要用于验证消息的来源是否真实，以及消息在传输过程中是否被篡改，当收发双方无利害冲突时，可防止第三者破坏。

(2) 数字签名不仅能验证消息来源和完整性，还能解决收发双方可能存在的纠纷，如发送方否认发送过某报文、接收方伪造报文等问题，满足不可否认性等要求。数字签名基于公钥密码体系，用私钥加密消息，公钥解密验证。

★★考点 11：MD5 算法的具体运算步骤（简答、计算）

(1) 对输入消息进行填充, 使其长度恰好为一个比 512 位的整数倍数仅小 64 位的比特数, 然后附上 64 位的实际消息二进制长度。

(2) 初始化 4 个 32 位链接变量 $A=0x01234567$, $B=0x89abcdef$, $C=0xfedcba98$, $D=0x76543210$ 。

(3) 以 512 位分组处理输入文本, 每一分组划分为 16 个 32 位字, 进入主循环。循环体内包含四轮运算, 每轮运算对 A、B、C、D 进行非线性函数运算, 并结合消息字和常数进行操作, 最后将 A、B、C、D 分别加上相应的中间结果。所有分组处理完后, 将 A、B、C、D 级联形成 128 位散列值。计算时要清楚每一轮运算中使用的函数、常数以及操作顺序。

★★考点 12: 基于对称密钥的身份认证过程 (简答)

(1) 以 Alice 和 Bob 通信为例, Alice 向 Bob 发送报文表明身份。

(2) Bob 选择一个一次性随机数 R 发送给 Alice。Alice 使用她与 Bob 共享的对称加密密钥 K_{A-B} 加密这个一次性随机数, 然后把加密的一次性随机数 $K_{A-B}(R)$ 发回给 Bob。

(3) Bob 解密接收到的报文, 如果解密得到的一次性随机数等于他发送给 Alice 的那个一次性随机数, 则可确认 Alice 的身份。该过程通过引入一次性随机数, 防止了重放攻击, 但依赖于双方共享的对称密钥。若密钥泄露, 身份认证将失效。

★★考点 13: 散列函数在消息完整性检测中的应用 (简答)

(1) 发送方对报文 m 应用散列函数 H, 得到固定长度的报文摘要 $H(m)$, 将扩展报文 $(m, H(m))$ 发送给接收方。

(2) 接收方收到扩展报文后, 提取出报文 m 和报文摘要 h, 同样对报文 m 应用散列函数 H 获得新的报文摘要 $H(m)$ 。

(3) 将接收方计算得到的 $H(m)$ 与接收到的 h 进行比较, 若两者相等, 则认为报文在传输过程中未被篡改, 消息完整性得到验证; 否则, 报文完整性遭到破坏。散列函数的单向性、抗碰撞性等特性保证了消息完整性检测的有效性。

★★考点 14: 公开密钥密码的加密和解密模型 (简答、绘图)

(1) 加密模型: 发送方 (如 Alice) 获取接收方 (如 Bob) 的公钥 K_B^+ , 用该公钥对要发送的报文 m 进行加密, 计算 $K_B^+(m)$, 并将加密后的报文发送给 Bob。

(2) 解密模型: Bob 接收到加密报文后, 使用自己的私钥 K_B^- 进行解密, 计算 $K_B^-(K_B^+(m))$, 还原出明文 m。

(3) 绘图时, 应清晰展示发送方、接收方、公钥、私钥、明文、密文以及加密和解密的过程, 标注各部分的流向和操作。公开密钥密码的安全性依赖于公钥加密算法的单向性和私钥的保密性。

★★考点 15: 常见对称密钥加密算法的特点对比 (简答)

(1) DES: 是 16 轮的 Feistel 结构分组密码, 分组长度和初始密钥长度为 64 位, 有效密钥长度 56 位, 安全性逐渐被证明不足, 已不再作为加密标准。

(2) AES: 分组长度和密钥长度均可变, 循环次数可根据安全要求修正, 汇聚了安全、高效、易用、

灵活等优点，抗线性攻击和抗差分攻击能力强。

(3) IDEA: 分组长度为 64 位，密钥长度 128 位，算法在硬件和软件上实现都很容易，且比 DES 算法速度快，对密码分析具有很强的抵抗能力，广泛应用于安全电子邮件 PGP 中。

(4) RC5: 分组长度 w 、密钥长度 b 和迭代轮数 r 都可变，形式简单，易于实现，运算速度快，适用于不同字长程序，对存储要求不高。

第九章 信息安全防护基本原理

★★考点 1: 消息完整性与数字签名 (单选、填空、简答)

(1) 消息完整性检测通过密码散列函数实现, 如 MD5 和 SHA-1, 要求函数具有算法公开、计算快速、定长输出、单向性、抗碰撞性等特性。

(2) 报文认证方法包括简单报文验证和报文认证码 (MAC)。简单报文验证易被攻击, MAC 虽改进但仍有缺陷。数字签名基于公钥密码体系, 能解决报文认证中的多种问题, 包括简单数字签名和签名报文摘要两种方式。

★★★考点 2: 身份认证 (单选、填空、简答、综合应用)

(1) 身份认证是实体在网络中证明自身身份的过程。常见方式有基于共享对称密钥和基于公钥的身份认证。

(2) 基于共享对称密钥认证时, 引入一次性随机数可预防重放攻击, 但需共享密钥; 基于公钥的身份认证结合一次性随机数和公钥加密技术, 但存在中间人攻击风险, 需解决密钥可信性问题。

(3) 具体认证过程: 基于共享对称密钥时, Alice 向 Bob 表明身份, Bob 发送随机数 R, Alice 用共享密钥加密 R 回传, Bob 解密验证; 基于公钥时, Alice 表明身份, Bob 发随机数 R, Alice 用私钥加密 R 回传, Bob 索要公钥并解密验证, 但此过程易受中间人攻击。

(4) 为解决中间人攻击问题, 可采用证书认证机构 (CA)。CA 验证实体身份后颁发数字证书, 将实体身份与公钥绑定, 用户通过获取和验证证书来确认公钥的真实性。

★★★考点 3: 密钥管理与分发 (单选、填空、简答、综合应用)

(1) 对称密钥分发的典型解决方案是引入密钥分发中心 (KDC)。通信双方与 KDC 各自保持长期共享密钥, KDC 为双方创建临时会话密钥, 有通信发起方生成会话密钥和 KDC 生成会话密钥两种方式。

(2) 公钥基础设施 (PKI) 利用公钥加密技术提供安全基础平台, 核心元素是数字证书, 核心执行者是 CA。PKI 包括 CA、数字证书库、密钥备份及恢复系统、证书作废系统 and 应用接口等基本构成部分。

(3) CA 负责数字证书的发放和管理, 验证实体身份并将其与公钥绑定, 数字证书遵循 X.509 国际标准。RA 系统是 CA 的延伸, 负责证书申请者的信息录入、审核和发放等工作。

★★考点 4: 访问控制 (单选、填空、简答、综合应用)

(1) 访问控制是限制用户对系统资源访问的手段, 目标是防止未授权访问, 直接支持保密性、完整性、可用性和合法使用等安全目标。

(2) 访问控制三要素包括主体 (访问动作发起者)、客体 (被访问对象) 和访问控制策略 (限制主体对客体的访问)。主流访问控制策略有自主访问控制、强制访问控制和基于角色的访问控制。

(3) 自主访问控制基于主体或主体组识别限制访问, 灵活但安全性低; 强制访问控制通过分配固定安全属性限制访问, 可保证信息保密性或完整性; 基于角色的访问控制以角色为中介授权, 便于管理, 提高

安全性。

★★考点 5: 内容安全 (单选、填空、简答)

(1) 内容安全包括内容保护和内容监管。内容保护技术如数据锁定、隐匿标记、数字水印和数字版权管理 (DRM) 等, 用于保护合法信息内容的版权。

(2) 数字水印是嵌入数字产品中的不可察觉且具有可鉴别性的数据, 具有隐蔽性、鲁棒性、安全性和易用性等特征, 有面向文本、图像、音视频等不同类型的水印算法。

(3) 内容监管针对非法信息, 包括网络信息内容监管和垃圾邮件处理。网络信息内容监管涉及监管策略制定、数据获取、数据调整、敏感特征搜索和违规判定及处理等; 垃圾邮件处理主要采用过滤、验证查询和挑战等技术。

★★考点 6: 物理安全 (单选、填空、简答)

(1) 物理安全是信息安全的基本保障, 目的是保护计算机设备、设施免受自然灾害、人为失误和犯罪行为破坏, 确保良好的电磁兼容工作环境。

(2) 物理安全包括环境安全、电磁保护、物理隔离及安全管理。环境安全涉及机房设计、防火、防盗等措施; 电磁保护通过屏蔽、滤波等措施提高设备抗干扰能力和降低电磁泄漏; 物理隔离技术经历了不同阶段, 如彻底的物理隔离、协议隔离和物理隔离网闸, 确保网络安全; 安全管理涵盖计算机网络系统管理和法规建设等内容。

★★考点 7: 消息认证码 (MAC) 的原理与应用 (简答)

(1) 原理: 发送方和接收方共享一个认证密钥, 发送方对报文 m 和认证密钥 s 应用散列函数 H , 得到报文认证码 $H(m+s)$, 将扩展报文 $(m, H(m+s))$ 发送给接收方; 接收方收到后, 对报文 m 和认证密钥 s 应用散列函数 H , 获得新的报文认证码 $H(m+s)$, 并与接收到的报文认证码比较, 若相等则报文认证成功。

(2) 应用: 常用于网络通信中, 确保消息在传输过程中未被篡改, 如在金融数据传输、重要文件传输场景中, 接收方通过验证 MAC 来确认消息的完整性和真实性, 防止数据被恶意篡改或伪造。但 MAC 存在缺陷, 接收方可能伪造报文并声称来自发送方, 因为它无法保证消息在接收方没有被篡改。

★★考点 8: 数字签名的实现过程及作用 (简答、综合应用)

(1) 实现过程: 简单数字签名是用私钥对报文进行加密, 签名报文摘要则是先对报文应用散列函数生成报文摘要, 再用私钥对摘要加密。

(2) 作用: 数字签名可确认消息来源的真实性, 防止发送方否认发送过某报文; 保证消息的完整性, 防止消息在传输过程中被篡改; 还能实现不可否认性, 即接收方不能否认收到过消息, 在电子商务、电子政务等领域有重要应用, 确保交易和文件的安全性和可靠性。

★★考点 9: 基于角色的访问控制 (RBAC) 的特点与优势 (简答)

(1) 特点: 以角色为中介进行授权和访问控制, 访问权限与角色相关联, 用户通过获得角色来获取相应权限; 系统中角色关系结构可层次化, 便于管理; 提供多种授权管理控制途径, 如改变客体访问权限、角色访问权限、主体所担任角色。

(2) 优势：提高安全性，能更精准地分配权限，减少多余权限；具有责任分离能力，定义角色和担任角色的人不同，不同角色权限相互制约；便于实现层次化管理，适应复杂的组织结构，在大型企业和组织的权限管理中具有显著优势，可降低管理复杂度，提高管理效率。

★★考点 10：内容监管系统的组成与工作流程（简答）

(1) 组成：内容监管系统分为监管策略和监管处理两部分。监管策略包括数据获取策略、敏感特征定义、违规定义以及处理策略；监管处理包括数据获取、数据调整、敏感特征搜索、违规判定以及违规处理等程序模块。

(2) 工作流程：首先根据监管策略确定监管对象和获取数据的方式，通过主动式（如网络爬虫）或被动式（设置探针）获取数据；然后对获取的数据进行调整，筛选、组合、解码和还原；接着进行敏感特征搜索，依据事先定义的敏感特征策略识别违规证据；之后进行违规判定，将搜索结果与违规定义比较；最后根据判定结果进行违规处理，如报警、封锁 IP、拦截连接等。

★★考点 11：物理隔离技术的发展阶段及特点（简答）

(1) 发展阶段：经历了彻底的物理隔离、协议隔离、物理隔离网闸三个阶段。彻底的物理隔离阻断网络间信息交流，适用于特定专用网络，但信息交流不便；协议隔离通过专用协议连接两个网络，阻断常规协议攻击，但仍存在安全风险；物理隔离网闸在物理上断开网络，通过分时操作实现安全的信息交换，具有更高的安全性。

(2) 特点：彻底的物理隔离简单直接，但信息交流困难；协议隔离在一定程度上解决了信息交换问题，但安全性有局限；物理隔离网闸既能保证网络断开时的安全性，又能实现高效的内、外网数据交换，且应用支持透明，有效防范信息外泄和网络攻击。

★★考点 12：身份认证中防止重放攻击的方法（简答）

(1) 引入一次性随机数：在认证过程中，如 Alice 与 Bob 通信时，Bob 发送一个一次性随机数 R 给 Alice，Alice 用共享密钥或私钥加密 R 后回传。Bob 通过验证解密后的随机数是否与发送的一致来确认消息新鲜性，由于随机数只使用一次，攻击者无法利用之前截获的加密信息进行重放攻击。

(2) 时间戳机制：在消息中添加时间戳，接收方根据当前时间与时间戳的差值判断消息的时效性。如果时间差值在合理范围内，则认为消息是新鲜的，有效防止攻击者重放旧消息。但该方法依赖系统时钟的同步精度，时钟不同步可能导致误判。

(3) 挑战-应答机制：与一次性随机数类似，验证方（如 Bob）向被验证方（如 Alice）发送挑战信息（可以是随机数或特定问题），被验证方根据挑战信息和共享密钥或私钥进行计算并返回应答。验证方通过验证应答的正确性来确认身份，每次挑战不同，使得重放的应答无效。

第十章 网络安全协议与技术措施

★★考点 1: 安全电子邮件基本原理及 PGP 协议 (单选、填空、简答)

(1) 安全电子邮件需求包括机密性、完整性、身份认证性和抗抵赖性。电子邮件系统单向性和非实时性的特点决定其适合对邮件本身加密,而非采用 VPN 等技术建立安全隧道。

(2) PGP 是事实上的安全电子邮件标准,可提供邮件加密、报文完整性等安全服务。其加密阶段:对报文用散列函数生成摘要,用发送方私钥签名,压缩后用对称密钥加密,再用接收方公钥加密对称密钥,最后进行 Base64 编码和分段处理。解密阶段:接收方依次进行 Base64 还原、分离,用私钥解密对称密钥,用对称密钥解密并解压缩,用发送方公钥验证签名。

★★考点 2: SSL 协议 (单选、填空、简答)

(1) SSL 是为解决 Web 应用安全问题而设计的协议,介于应用层和传输层之间,可提供机密性、完整性、身份认证等安全服务。SSL 协议栈包含握手协议、更改密码规范协议、警告协议和记录协议,其使用的密码包括公开密钥加密算法(如 RSA)、对称密钥加密算法(如 DES、3DES)和 MAC 算法(如 MD5、SHA-1)。

(2) SSL 握手过程:客户端发送支持的算法列表和随机数,服务器选择算法并返回公钥证书和随机数;客户端验证证书,生成预主密钥并用服务器公钥加密后发送;双方基于预主密钥和随机数计算加密密钥和 MAC 密钥;客户端和服务端分别发送针对所有握手消息的 MAC,保护握手过程免遭篡改。

★★★考点 3: IPSec 协议与 VPN (单选、填空、简答、综合应用)

(1) VPN 通过在公共网络上建立安全通道,实现远程用户、分支机构等与总部网络的安全连接,其关键技术有隧道技术(包括乘客协议、封装协议、承载协议)、数据加密、身份认证等。

(2) IPSec 是网络层安全协议,可提供机密性、身份鉴别等安全服务,有传输模式和隧道模式。其关键协议包括 AH 协议(提供源认证和鉴别、数据完整性检验)和 ESP 协议(提供源认证和鉴别、数据完整性检验以及机密性)。安全关联(SA)是 IPSec 通信实体间的单向连接,建立时需维护安全参数索引、序列号等参数,相关信息存储在安全关联数据库(SAD)和安全策略数据库(SPD)中。IPSec 密钥交换(IKE)用于自动协商建立 SA 和交换密钥,包括 ISAKMP、OAKLEY 和 SKEME 三个主要部分,支持预共享密钥和公钥基础设施两种认证方式。

★★考点 4: 防火墙概念、分类与功能 (单选、填空、简答)

(1) 防火墙是位于两个网络间执行访问控制策略的系统,可隔离内部和公共网络,允许或阻止分组进出。按软、硬件形式可分为软件防火墙、硬件防火墙和芯片级防火墙;按在网络协议栈过滤层次可分为包过滤防火墙、电路级网关防火墙和应用层网关防火墙;按应用部署位置可分为边界防火墙、个人防火墙和混合式防火墙。

(2) 防火墙功能包括服务控制、方向控制、用户控制和行为控制,可防止非法用户进入内部网络、方

便网络安全性监视与报警、部署网络地址转换、审计和记录 Internet 使用量等,但也存在限制有用网络服务、无法防护内部攻击等局限性。防火墙设计原则有拒绝没有特别允许的任何事情和允许没有特别拒绝的任何事情两种策略。

★★★考点 5: 防火墙实现原理与体系结构 (单选、填空、简答、综合应用)

(1) 防火墙基本原理是检查通过的数据包相关信息,依据网络协议及其封装数据进行安全检查。基本技术包括数据包过滤(根据过滤规则对数据包进行过滤)和代理服务(代理服务器根据安全策略处理用户请求)。

(2) 包过滤防火墙分为静态包过滤防火墙和状态检测防火墙。静态包过滤防火墙工作在网络层,根据数据包的源 IP 地址、目的 IP 地址等信息进行过滤;状态检测防火墙在静态包过滤基础上增加状态检测能力,通过连接状态表跟踪连接状态。代理型防火墙分为应用层网关防火墙和电路级网关防火墙,应用层网关防火墙工作在应用层,对特定应用进行协议分析与过滤;电路级网关防火墙工作在会话层,监视 TCP 握手信息,判定会话合法性。

(3) 防火墙体系结构有双宿/多宿主体系结构、屏蔽主机体系结构和屏蔽子网体系结构。双宿/多宿主体系结构通过应用层数据共享或代理服务实现两个网络间通信;屏蔽主机体系结构由包过滤路由器和堡垒主机组成,实现网络层和应用层安全;屏蔽子网体系结构使用两个包过滤路由器和一个堡垒主机,增加了周边网络保护,安全性更高。

★★考点 6: 防火墙部署与应用 (单选、填空、简答、综合应用)

(1) DMZ 是介于信赖域和非信赖域之间的安全区域,用于放置需要对外提供服务的服务器。外部防火墙保护 DMZ 系统及内部网络,内部防火墙为 DMZ 系统和内部网络提供双重保护。

(2) 分布式防火墙由网络防火墙、主机防火墙和中心管理服务器组成,中心管理服务器统一制定安全策略并分发到各节点。与传统防火墙相比,它打破了对网络拓扑的依赖,增加了针对主机的入侵检测和防护功能。

(3) 个人防火墙是安装在个人计算机上的软件系统,采用基于应用层网关、基于 IP 地址和端口的安全规则、端口“隐蔽”功能、邮件过滤功能等技术,可防止 Internet 上用户的攻击、阻断木马及其他恶意软件的攻击等。

★★考点 7: 入侵检测系统概述 (单选、填空、简答)

(1) 入侵检测是对防火墙等传统安全保护方法的补充,能实时监测入侵行为并报警。入侵检测过程包括信息收集(收集系统和网络日志文件、目录和文件的异常改变等信息)、数据分析(通过模式匹配、统计分析和完整性分析等技术手段)和响应(根据检测结果采取相应措施)。

(2) 入侵检测系统功能包括监控用户和系统活动、审计系统配置和弱点等,其功能结构由感应器、分析器和管理器组成。入侵检测系统可分为基于主机的入侵检测系统、基于网络的入侵检测系统和分布式入侵检测系统;按分析方法可分为异常入侵检测系统和误用入侵检测系统;按响应方式可分为主动入侵检测系统和被动入侵检测系统。

★★考点 8：入侵检测技术原理与方法（单选、填空、简答）

(1) 入侵检测系统基本工作模式包括从系统不同环节收集信息、分析信息、自动响应和记录报告结果。常用检测方法有特征检测（对已知攻击模式进行匹配检测）、统计检测（基于统计模型检测异常行为）和专家系统（利用规则对入侵进行检测）。

(2) 特征检测准确率高，但对未知攻击无能为力；统计检测能检测未知攻击，但误报、漏报率高；专家系统依赖知识库完备性，可对有特征的入侵行为进行检测。

★★考点 9：安全电子邮件协议 PGP 的应用（综合应用）

(1) 给出具体的邮件场景，要求考生分析 PGP 在该场景下的加密、解密过程，如确定加密时使用的密钥、签名的生成与验证方式等。

(2) 结合实际需求，设计基于 PGP 的安全邮件通信方案，包括密钥的管理与分发、如何保证邮件的完整性和机密性等，并分析方案的安全性。

★★考点 10：SSL 协议栈中各协议的功能（简答）

(1) SSL 握手协议：负责协商密钥组、建立密钥，进行服务器和客户的认证与鉴别，是 SSL 协议的关键部分，其协商结果是记录协议的基础。

(2) SSL 更改密码规范协议：用于在通信过程中修改密钥组，标志着加密策略的改变，运行在记录协议之上，报文内容封装在记录协议报文中。

(3) SSL 警告协议：当握手过程或数据加密出错或发生异常时，向对等实体传递 SSL 警告或终止当前连接，包含警告级别和警告代码两个字节。

(4) SSL 记录协议：描述 SSL 信息交换过程中的消息格式，将数据分段、压缩，计算 MAC 值并加密，添加记录头后放入 TCP 报文段传输，记录头包含内容类型、版本号和数据长度。

★★考点 11：IPSec 协议的传输模式与数据报结构（简答、综合应用）

(1) 传输模式 AH：在原 IP 头和原 IP 数据报载荷之间加入 AH 头，AH 头包含下一个头字段、载荷长度字段等，对原 IP 头不变字段、AH 头、原 IP 数据报载荷进行认证，但不包括原 IP 头中可变量段。

(2) 隧道模式 AH：构建新的 IP 头，认证时包括新的 IP 头，适用于数据报在公共网络中传输的场景。

(3) 传输模式 ESP：在原 IP 数据报载荷后面添加 ESP 尾部，进行填充以满足分组密码要求，ESP 头包含 SPI 和序列号，对 ESP 头、原 IP 数据报载荷及 ESP 尾部进行认证计算 MAC，原 IP 头不变。

(4) 隧道模式 ESP：使用最广泛，将 ESP 头、原 IP 头、原 IP 数据报载荷、ESP 尾部、ESP 认证数据一起封装到新的 IP 数据报载荷中，并添加新的 IP 头。

★★考点 12：防火墙的分类及特点（单选、简答）

(1) 按软、硬件形式分类：软件防火墙运行于一般计算机上，需操作系统支持；硬件防火墙由特定计算机和软件构成；芯片级防火墙基于专用硬件平台和嵌入式实时操作系统，速度快、处理能力强、抗攻击能力高。

(2) 按在网络协议栈过滤层次分类：包过滤防火墙工作在网络层和传输层，根据数据包的源 IP 地址、

目的 IP 地址等进行过滤；电路级网关防火墙工作在会话层，监控 TCP 握手信息；应用层网关防火墙工作应用层，对应用层协议进行分析和过滤。

(3) 按应用部署位置分类：边界防火墙位于内部和外部网络边界，保护内部网络；个人防火墙安装在单台主机上，保护个人计算机；混合式防火墙由多个软件和硬件组件组成，分布于网络不同位置，对内部和外部网络通信进行过滤。

★★考点 13：入侵检测系统的检测方法（单选、填空、简答）

(1) 特征检测：对已知的攻击或入侵方式做出确定性描述，形成事件模式，当被审计事件与已知入侵事件匹配时报警，准确率高但对未知攻击无效。

(2) 统计检测：通过建立系统对象的统计描述，将网络、系统行为与正常测量属性比较，检测异常行为，能检测未知和复杂入侵，但误报、漏报率高。

(3) 专家系统：使用规则对入侵进行检测，针对有特征的入侵行为，其建立依赖于知识库的完备性，可根据经验积累进行规则扩充和修正。

第十一章 信息安全管理与法律法规

★★考点 1: 网络风险分析与评估 (单选、填空、简答)

(1) 影响互联网安全的因素包括互联网的开放性、自身脆弱性、安全威胁与攻击的普遍性、安全管理的困难性。网络风险评估是对信息及信息处理设施的威胁、影响、脆弱性及三者发生可能性的评估,其意义在于明确企业信息系统安全现状、确定主要安全风险、指导安全技术和管理体系建设。

(2) 网络安全风险包括软、硬件设计故障导致网络瘫痪、黑客入侵、敏感信息泄露、信息删除等。网络风险评估要素包括资产、威胁、脆弱性等,各要素相互关联,如业务战略依赖资产实现,资产价值受业务战略依赖度影响,威胁利用脆弱性形成风险等。网络风险评估模式涵盖评估目标、范围、原则、实施过程和安全加固实施建议,评估过程包括前期准备、现场调查、风险分析和安全规划阶段。

★★★考点 2: 等级保护与测评 (单选、填空、简答、综合应用)

(1) 信息安全等级保护是国家信息安全保障的基本制度,相关法律法规包括《中华人民共和国计算机信息系统安全保护条例》《计算机信息系统安全保护等级划分准则》《中华人民共和国网络安全法》等。定级原则坚持“自主定级、自主保护”与国家监管相结合,依据信息系统在国家安全、经济建设等方面的重要程度,以及遭到破坏后对相关客体的危害程度确定安全保护等级。

(2) 信息系统安全保护等级分为 5 级,由业务信息安全和系统服务安全两方面的定级要素决定,包括受侵害的客体(公民、法人和其他组织的合法权益、社会秩序和公共利益、国家安全)和对客体的侵害程度(一般损害、严重损害、特别严重损害)。定级流程包括确定定级对象、确定业务信息和系统服务安全受侵害的客体及侵害程度,依据矩阵表得出业务信息安全保护等级和系统服务安全保护等级,取较高者作为定级对象的安全保护等级。

(3) 等级测评是对非涉及国家秘密信息系统安全等级保护状况进行检测评估的活动,作用是帮助运营、使用单位进行现状分析和整改。执行主体需满足特定条件,如在境内注册、无违法犯罪记录等。等级测评过程分为测评准备、方案编制、现场测评和分析及报告编制 4 个活动。

★★★考点 3: 信息安全相关标准 (单选、填空、简答)

(1) 国际信息安全标准:《信息技术安全性评估通用准则》(CC)为信息技术产品和系统的安全性评估提供统一方法与框架;《信息技术系统风险管理指南》(NISTSP800-30)帮助组织识别、评估和管理信息技术系统中的风险;系统安全工程能力成熟度模型(SSE-CMM)用于评估和改进组织系统安全工程实践;ISO/IEC27000 系列标准为信息安全管理体系提供全面框架。

(2) 我国信息安全标准:涵盖国家标准、行业标准、政府监管和指导文件等多个层次,积极与国际接轨。重要标准包括《信息安全技术网络安全等级保护基本要求》《信息安全技术个人信息安全规范》《信息安全技术信息安全管理体系要求》等,涉及网络安全、数据安全、信息系统安全管理等领域。

★★考点 4: 信息安全法律法规的基本原则与法律地位 (单选、填空、简答)

(1) 基本原则：谁主管谁负责原则，明确各部门在信息安全管理中的职责；突出重点原则，重点维护重要领域计算机信息系统安全；预防为主原则，注重对安全威胁的预防；安全审计原则，对系统活动进行审计跟踪；风险管理原则，主动识别和应对系统风险。

(2) 法律地位：信息安全法律具有安全法和网络法的双重地位，在我国法律体系中需优先发展。其作用包括指引、评价、预测、教育和强制等，为信息安全提供法律保障，规范人们的行为。

★★考点 5：国外信息安全相关法律法规（单选、填空、简答）

(1) 美国：政府信息安全法律法规如《信息自由法》《爱国者法》《联邦信息安全管理法案》等；商业组织信息安全方面，通过普通法、成文法及合同协议保护商业秘密，《数字千年版权法》保护版权作品；个人隐私信息安全方面有《隐私保护法》《电子通信隐私法》等众多联邦成文法。

(2) 英国：《数据保护法 2018》实施欧盟《通用数据保护条例》，保护个人数据；《网络与信息系统法规 2018》提高关键基础设施和数字服务提供商的网络安全水平；《计算机滥用法 1990》规定了对未经授权计算机访问等行为的处罚。

(3) 日本：《个人信息保护法》规定个人信息处理原则，设立个人信息保护委员会；《网络安全基本法》促进国家层面网络安全措施；《电子签名及认证服务法》规范电子签名和认证服务。

★★考点 6：我国信息安全相关法律法规（单选、填空、简答）

(1) 法律类：《中华人民共和国电子签名法》为电子签名提供法律框架；《中华人民共和国网络安全法》加强网络安全管理；《中华人民共和国密码法》规范密码应用和管理；《中华人民共和国数据安全法》保障数据安全；《中华人民共和国个人信息保护法》保护个人信息权益。

(2) 行政法规及其他类：《中华人民共和国计算机信息系统安全保护条例》《互联网信息服务管理办法》等，涉及网络与信息系统安全、信息内容安全等多个方面，初步形成我国信息安全的法律体系。这些法律法规从不同层面规范了信息安全相关行为，明确各方权利义务，对违反信息安全的行为进行处罚，为信息安全保障体系建设提供了有力支持。

★★考点 7：网络风险评估的要素关系（简答）

(1) 业务战略依赖资产实现，资产价值受业务战略依赖度影响，依赖度越高价值越大。

(2) 资产价值越大，面临风险越大，风险由威胁引发，资产面临威胁越多风险越大，且可能演变成安全事件。

(3) 脆弱性是未被满足的安全需求，弱点越多，威胁利用脆弱性导致安全事件的可能性越大，威胁通过利用脆弱性危害资产形成风险。

(4) 风险的存在导出安全需求，安全需求可通过安全措施满足，实施时需考虑资产价值和成本。安全措施能抵御威胁，降低安全事件发生可能性和影响，但会存在残余风险，需密切监视，因其可能诱发新的安全事件。

★★考点 8：信息安全等级保护的定级要素与定级方法（简答、综合应用）

(1) 定级要素：包括受侵害的客体（公民、法人和其他组织的合法权益、社会秩序和公共利益、国家

安全) 和对客体的侵害程度 (一般损害、严重损害、特别严重损害)。

(2) 定级方法: 先确定作为定级对象的信息系统, 分别确定业务信息安全和系统服务安全受到破坏时所侵害的客体及侵害程度, 依据相应矩阵表得出业务信息安全保护等级和系统服务安全保护等级, 取两者较高者作为定级对象的安全保护等级。在确定过程中, 要准确判断侵害客体和评估侵害程度, 综合考虑多方面因素。

★★考点 9: 信息安全法律法规的作用 (简答)

- (1) 指引作用: 为人们提供行为模式, 指引可做、必须做或不得做的行为。
- (2) 评价作用: 判断、衡量他人行为是否合法及违法性质和程度。
- (3) 预测作用: 让当事人预估相互行为及法律后果。
- (4) 教育作用: 通过法律实施影响一般人今后的行为。
- (5) 强制作用: 制裁、惩罚违法行为, 保障信息安全环境。

★★考点 10: 国际信息安全标准的特点及应用 (简答)

(1) 《信息技术安全性评估通用准则》(CC): 提供统一的安全性需求和评估方法, 促进全球信息技术安全评估标准化, 确保产品和系统安全性达到预期标准, 适用于信息技术产品和系统的安全性评估。

(2) 《信息技术系统风险管理指南》(NISTSP800-30): 帮助组织识别、评估和管理信息技术系统中的风险, 提供风险管理的方法论和一般原则, 适用于各类组织保护信息系统和数据安全。

(3) ISO/IEC27000 系列标准: 为信息安全管理体系提供全面框架, 帮助组织保护信息资产, 通过 PDCA 过程模型, 适用于不同类型和规模的组织建立、实施和改进信息安全管理体系。

(4) 系统安全工程能力成熟度模型 (SSE-CMM): 基于成熟度模型概念, 评估组织系统安全工程实践过程和能力, 帮助识别改进领域, 与其他安全标准相辅相成, 提供全面的安全工程和风险管理指导。

(5) OCTAVE: 一种信息安全风险评估方法论, 适用于大型组织和政府机构, 通过整合管理和技术措施, 帮助组织全面理解和管理信息安全风险, 从技术和组织两方面理清关键资产、威胁和薄弱点。

★★考点 11: 我国信息安全标准中与网络安全等级保护相关的内容 (单选、填空、简答)

(1) 《信息安全技术网络安全等级保护基本要求》(GB/T22239—2019): 规定不同等级信息系统需要满足的安全要求, 是网络安全等级保护工作的基础, 明确了各个等级在物理安全、网络安全、主机安全、应用安全和数据安全等层面的具体要求。

(2) 《信息安全技术网络安全等级保护实施指南》(GB/T25058—2019): 规定等级保护对象实施网络安全等级保护工作的过程, 包括定级、备案、建设整改、等级测评和监督检查等环节的具体实施方法和要求。

★★考点 12: 网络风险评估的实施过程 (简答)

(1) 前期准备阶段: 明确评估目标、范围、成果表现形式和项目计划, 确定个人职责与任务分工, 为后续工作做准备。

(2) 现场调查阶段: 通过人员访谈与调查, 收集整理组织机构的信息系统、安全管理策略、关键资产安全状况等资料, 形成调查报告。

(3) 风险分析阶段：依据现场收集的资料，结合专业知识，分析信息系统面临的威胁、存在的脆弱性以及威胁事件的影响，评估信息系统风险。

(4) 安全规划阶段：根据风险分析结果选择适当安全策略，结合组织应用特点形成策略体系，为决策提供参考。

★★考点 13：信息安全等级测评的风险及应对措施（简答）

(1) 风险：验证测试可能影响系统正常运行，存在误操作风险；工具测试可能对系统负载、服务器和网络通信造成影响甚至伤害；可能导致敏感信息泄露，如网络拓扑、IP 地址等信息。

(2) 应对措施：在测评前充分了解系统，制定详细测试计划，尽量减少对系统的影响；对测试工具进行严格评估和筛选，确保其安全性；加强对测评人员的管理和监督，签订保密协议，明确保密责任，防止敏感信息泄露。